

Sicurezza 42

Benvenuto. Ottima scelta quella di iniziare ad analizzare nel dettaglio la sicurezza di rete, un pilastro fondamentale sia per l'Esame di Stato sia per la tua futura carriera nell'IT. Affrontare la seconda prova richiede non solo la conoscenza a memoria dei protocolli, ma la capacità di applicarli per risolvere scenari reali.

Procediamo con metodo ingegneristico, analizzando il materiale e applicandolo a un caso pratico aziendale.

1. Riassunto Tecnico: Sicurezza di Rete

Il documento fornito si concentra sui concetti cardine della difesa perimetrale e della traduzione degli indirizzi.

1.1 Il Firewall e la Difesa Perimetrale

Il firewall è un componente di difesa perimetrale, implementabile sia tramite hardware dedicato sia tramite funzionalità logiche software all'interno di un router. Il suo scopo fondamentale è separare la LAN locale da Internet per prevenire intrusioni, filtrando i pacchetti in ingresso e in uscita secondo regole (policy) prestabilite. Affinché sia efficace, la sicurezza deve essere ricondotta a un unico nodo che comunica con l'esterno. Esistono anche firewall personali che filtrano solo il traffico del singolo computer su cui sono installati.

I firewall si dividono in tre categorie principali in base al livello dello stack TCP/IP in cui operano:

Categoria	Livello Stack TCP/IP	Funzionamento e Caratteristiche
Packet Filter	Network e Transport	Filtra i pacchetti tramite le Access Control List (ACL) analizzando solo pochi byte dell'header (IP sorgente/destinazione, Porta TCP/UDP, Protocollo). È molto veloce ma non controlla i dati all'interno del pacchetto.
Stateful Inspection	Network e Transport	Oltre ad esaminare gli indirizzi, registra le porte e mantiene memoria della conversazione tra due endpoint. È in grado di rilevare deviazioni rispetto al traffico standard.
Application Level	Application	Esamina applicazioni e protocolli di livello applicativo (es. FTP, HTTP, DNS). A questa categoria appartengono i proxy, che permettono connessioni selettive tra rete privata e pubblica. Offre massima protezione (inclusi DNS criptato e VPN) ma riduce la velocità della rete.

1.2 La Demilitarized Zone (DMZ)

La DMZ è un'area logica o fisica progettata per contenere i servizi esposti a reti inaffidabili, come Internet, proteggendo così i dati sensibili della LAN interna. È una zona caratterizzata da un numero inferiore di regole. Chi accede dall'esterno non è autorizzato ad entrare nella LAN, ma può usufruire solo dei servizi in DMZ.

- Servizi tipici in DMZ:** Server WEB, MAIL, FTP e VoIP. Per motivi di sicurezza, spesso vi si installano anche proxy server.
- Gestione flussi:** Se i server WEB e MAIL devono accedere a database situati nella LAN interna, tale comunicazione deve essere strettamente controllata da un application firewall.
- Architetture:** Può essere realizzata con un singolo firewall (a tre interfacce) o con un doppio firewall (creando una zona cuscinetto fisica).

1.3 NAT e PAT: Traduzione degli Indirizzi

Il Network Address Translation (NAT) mappa due spazi di indirizzi IP, traducendo solitamente un indirizzo IP privato in uno pubblico. Questo è necessario perché gli indirizzi privati non sono validi sulla rete pubblica e permette inoltre di tenerli nascosti. Il NAT modifica l'header del livello Network, mentre il PAT (Port Address Translation) modifica sia l'header Network sia quello Transport.

Ecco le varianti principali:

- Static NAT:** Traduzione statica e bidirezionale 1:1 tra un IP privato e un IP pubblico (non conserva gli indirizzi).
- Static PAT:** Noto come Port Forwarding. Traduce in modo statico e bidirezionale un IP e porta privati in un IP e porta pubblici, permettendo a più host di usare un unico IP pubblico.
- Dynamic NAT:** Più IP privati vengono tradotti in più IP pubblici dinamicamente; è bidirezionale finché la connessione resta attiva.
- Dynamic PAT:** La porta viene assegnata dinamicamente e in modo randomico; è unidirezionale (l'esterno non può avviare la connessione verso l'interno).
- Policy NAT:** Traduce la sorgente considerando sia l'indirizzo sorgente sia quello di destinazione.
- Twice NAT:** Traduce sia la sorgente sia la destinazione, basandosi sempre sulla combinazione di sorgente e destinazione.

2. Caso Aziendale: "TechNova S.r.l." (Simulazione Seconda Prova)

Scenario: L'azienda TechNova richiede la progettazione di un'infrastruttura di rete sicura. Ha bisogno di una LAN interna per i dipendenti, e deve esporre un Web Server aziendale accessibile da Internet.

2.1 Analisi dei Requisiti e Architettura

Basandoci sui principi di sicurezza, adotteremo un'Architettura a Doppio Firewall per creare una DMZ fisica.

- LAN Interna:** Contiene i PC dei dipendenti e i database sensibili. Nessun accesso diretto da Internet.
- DMZ:** Conterrà il Web Server. Separata dalla LAN e da Internet per proteggere i dati sensibili.
- WAN:** La connessione verso l'ISP.

2.2 Dimensionamento IP (Esempio di Subnetting)

Utilizziamo indirizzamenti privati (da tradurre poi tramite NAT).

IP Pubblico assegnato dall'ISP (WAN): 200.100.50.0 /29
Spazio IP Privato scelto: 192.168.0.0 /16

```
- Subnet LAN: 192.168.10.0 /24 (Gateway: 192.168.10.1)
- Subnet DMZ: 192.168.20.0 /24 (Gateway: 192.168.20.1)
  -> Web Server IP: 192.168.20.100
```

2.3 Scelte Tecnologiche di Sicurezza (Firewall e NAT)

- **Firewall Perimetrale (Esterno - tra WAN e DMZ):** Sarà configurato per permettere solo il traffico in ingresso sulla porta 80/443 destinato al Web Server.
- **Firewall Interno (tra DMZ e LAN):** Sarà un *Application Level Firewall*, fondamentale perché il Web Server nella DMZ dovrà interrogare il Database nella LAN. Questa comunicazione deve essere rigorosamente controllata.
- **Accesso a Internet per la LAN:** I PC dei dipendenti (es. 192.168.10.X) useranno un **Dynamic PAT** sul router per navigare in Internet, permettendo a più host privati di usare l'unico IP pubblico dell'interfaccia WAN, operando in modo unidirezionale (sicurezza contro connessioni dall'esterno).
- **Esposizione del Web Server:** Utilizzeremo lo **Static PAT (Port Forwarding)**. L'IP pubblico (es. 200.100.50.2:443) verrà tradotto staticamente e in modo bidirezionale verso l'IP privato del server in DMZ (192.168.20.100:443).

2.4 Diagramma Logico Testuale

Plaintext

```
(INTERNET)
|
[Router WAN / Firewall Esterno] --> (Applica Static PAT per Web Server / Dynamic PAT per LAN)
|
|--- [DMZ Rete: 192.168.20.0/24] --- (Web Server: 192.168.20.100)
|
[Firewall Interno / Application Level] --> (Controlla flussi DMZ -> Database)
|
[Switch Core LAN]
|
|--- [VLAN Dipendenti: 192.168.10.0/24]
|--- [VLAN Server DB (Dati Sensibili)]
```

3. Tips per la Maturità

1. **Motiva sempre le scelte:** In sede d'esame, non basta dire "uso il NAT". Devi specificare *quale* NAT. Ad esempio: "Utilizzo il Dynamic PAT per la LAN perché permette il multiplexing di molteplici indirizzi privati su un solo IP pubblico assegnando porte casuali e garantendo l'unidirezionalità delle connessioni".
2. **Attenzione alla DMZ:** Se la traccia richiede di esporre dei servizi (es. sito web, portale e-commerce), inseriscili *sempre* in una DMZ. I commissari valutano pesantemente l'errore di mettere un server pubblico direttamente nella LAN. Ricorda di menzionare che l'accesso ai DB interni deve essere filtrato a livello applicativo.
3. **Usa il lessico appropriato:** Termini come *Stateful Inspection*, *Port Forwarding*, *ACL* dimostrano padronanza tecnica.

Hai compreso pienamente la differenza tra uno Static PAT (usato per i server in ingresso) e un Dynamic PAT (usato per far navigare gli utenti)? Vuoi che proviamo a configurare a livello testuale le Access Control List (ACL) per il firewall che separa la DMZ dalla LAN, simulando un quesito pratico della prova?